



AURA HEALTH COMPLIANCE

EXECUTIVE SUMMARY



Executive Summary

Aura Health is a Medical insurance company that handles important patient medical and financial data. The executives have recently noticed that a good number of its employees are not well informed on the handling of client data.

They have requested the development of operational policies to ensure

- Improved security awareness
- Safer Data handling etiquette
- Improved incidence response capabilities.
- Ensure business continuity by making sure industry level security standards are strictly adhered to.

This documentation gives a summary of all the processes involved in the development and enforcement of these policies.

DEVELOPMENT OF POLICIES

The following policies were developed by the IT Security and Compliance Dept;

- Information Security Policy
- Data Protection and Privacy Policy
- Incident Management Policy



Information security policy; this policy is a framework that oversees the groundwork for protecting the confidentiality, integrity, and availability of Aura Health’s data. It also provides a guide for security processes that are used to safeguard an organization's assets.

It also dictates how staff are to interact with aforementioned assets to ensure uninterrupted daily operations.



CONTROL PAGE

Document Title	Information Security Policy
Document Number	AH-POL-ISP-001
Version	1.0
Classification	Internal – Confidential
Author	IT Security and Compliance Dept.
Owner	Chief Information Security Officer
Approved By	Board executives and Compliance officer
Issue Date	March 25th, 2026
Next Review Date	April 1st, 2027
Document Location	Aura Health Internal Policy Repository
Distribution List	All Depts. Executive, IT, HR, Legal.
Related Policies	Incident Management Policy, Data Protection and Privacy Policy.



Data Protection and Privacy Policy; To ensure the privacy of customer medical and financial information in line with healthcare regulations. This policy covers all sensitive data handled, stored, or sent by Aura Health.



CONTROL PAGE

Document Title	Data Protection and Privacy Policy
Document Number	AH-POL-DPP-001
Version	1.0
Classification	Internal - Confidential
Author	IT Security & Compliance Department
Owner	Chief Information Security Officer
Approved By	Board executives and Compliance officer
Issue Date	March 25th, 2026
Next Review Date	April 1st, 2027
Document Location	Aura Health Internal Policy Repository
Distribution List	All Depts. Executive, IT, HR, Legal.
Related Policies	Incident Management Policy, Information Security Policy



Incident Management Policy; To establish a fast and organized response to security threats and events. This applies to all reported security weaknesses and confirmed data breaches.



CONTROL PAGE

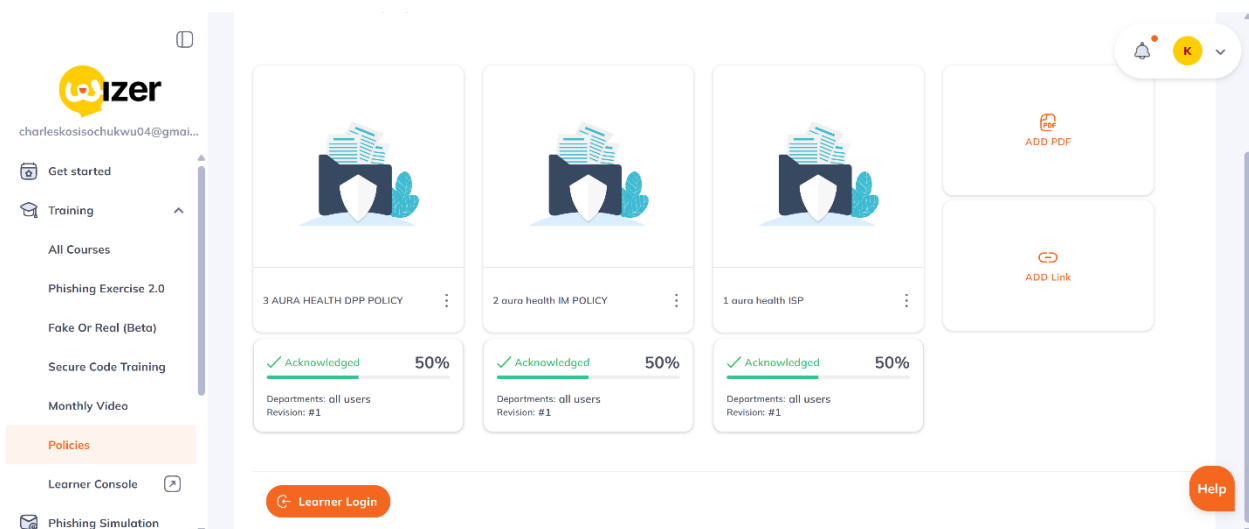
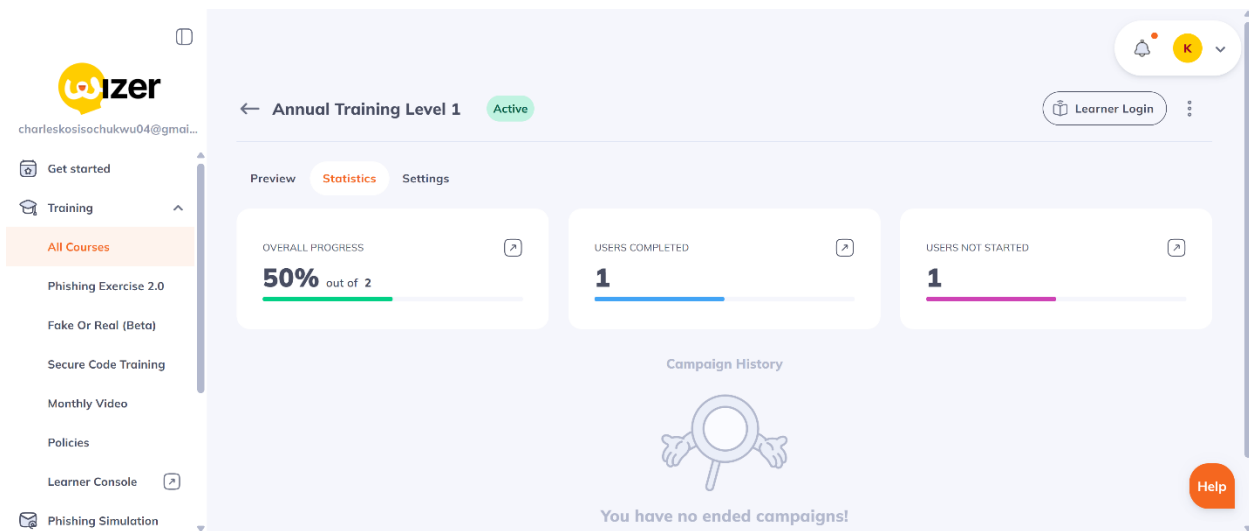
Document Title	Incidence Response Policy
Document Number	AH-POL-IMP-001
Version	1.0
Classification	Internal – Confidential
Author	IT Security and Compliance Dept.
Owner	Chief Information Security Officer
Approved By	Board executives and Compliance officer
Issue Date	March 25th, 2026
Next Review Date	April 1st, 2027
Document Location	Aura Health Internal Policy Repository
Distribution List	All Depts. Executive, IT, HR, Legal.
Related Policies	Information Security Policy, Data Protection and Privacy Policy.



Security Awareness training:

A training course has been developed by the IT and compliance team to ensure that every staff follows through with all requirements in the security policies. This is communicated and monitored and enforced through the *Wizer* tool.

Below are snapshots showing the dashboard for monitoring staff progress with the security training as well as the policies uploaded:





Recommendations:

1. Implement Continuous Monitoring via SIEM

Instead of relying solely on monthly reports, deploy a Security Information and Event Management (SIEM) system. This provides real-time visibility into access patterns.

2. Conduct Regular Tabletop Exercises

Policies on paper often fail in practice. Once every six months, gather the Incident Response Team and executives for a simulated breach (e.g., a ransomware attack or a lost laptop with PHI).

3. Automate the Vendor Risk Assessment

Since vendors must sign a Data Processing Agreement (DPA), use a digital platform to track their compliance status and expiration dates.

4. Improved Security Awareness Training

Move beyond a once-a-year "check the box" slideshow. Use monthly micro-learning modules or phishing simulations.

5. Ensure that "near-misses" directly lead to system hardening.